

AI Chatbot Interface Development

AI Assistant for Cybersecurity Compliance and Regulatory frameworks

By: Hamza Habib, Saad Foda, Kamar El-hayouni

Supervised by: Calin Anton
and Mohamed El-Hajj

AGENDA

01 INTRODUCTION

- Problem
- Project Goal
- Motivation

02 OBJECTIVES AND APPROACH

- Method Overview
- Data

03 WORK COMPLETED

- Data Collection
- Challenges Resolved

04 DEMO

05 CONCLUSION

- Successes
- Limitations
- Future Work

06 QUESTIONS

01

Introduction

Problem We Are Solving

Global Compliance & Regulatory Framework Matrix

Comprehensive overview of security, privacy, AI, and resilience regulations across jurisdictions and industries

JURISDICTION: All Jurisdictions
INDUSTRY/SECTOR: All Industries
TOPIC DOMAIN: All Topics
REGULATION TYPE: All Types

62 regulations shown

8 jurisdictions

8 industries covered

NAME & TYPE	DESCRIPTION	JURISDICTION	INDUSTRY/SECTOR	TOPIC DOMAIN	ENFORCEMENT	EFFECTIVE DATE	KEY REQUIREMENTS
 NIST Cybersecurity Framework FRAMEWORK	Voluntary framework consisting of standards, guidelines, and best practices to manage cybersecurity-related risk	US	Cross-Industry Government Financial Services	Cybersecurity Risk Management	✓ Voluntary	 2014-02	- Identify critical assets - Protect systems - Detect events
 CCPA ACT	California Consumer Privacy Act providing consumers with rights over their personal information	US	Cross-Industry	Data Privacy	⚠ Mandatory	 2020-01	- Right to know - Right to delete - Right to opt-out
 HIPAA ACT	Health Insurance Portability and Accountability Act protecting sensitive patient health information	US	Healthcare	Data Privacy Cybersecurity	⚠ Mandatory	 1996-08	- Administrative safeguards - Physical safeguards

Current System

- Static HTML interface displaying compliance frameworks
- No backend or intelligent search functionality
- Users must manually read long regulatory documents

Problem

- Cybersecurity frameworks contain hundreds of pages
- Finding relevant requirements is time-consuming

Project Goal



Natural Language Queries

Allows users to ask questions about compliance in plain language

Context-Aware Guidance

Receive clear answers with relevant context and PDF citations

Identify Regulations

Understand which laws and frameworks apply

Compare Frameworks

Compare standards like NIST and PCI DSS

Reduce Time and Errors

Minimize manual research and improve accuracy

Interactive Experience

Support multi-turn conversations for guided discovery

Motivation

- Compliance professionals spend hours searching
- High risk of **missing critical requirements**
- No personalization or guidance for specific situations
- No clear way to understand *“what applies to me”*

02

Objectives and Approach

Technical Overview

Objectives and Approach

- Build a cybersecurity compliance assistant
- Allow admins to upload documents (PDF/text)
- Enable natural language querying
- Use Retrieval-Augmented Generation (RAG)
- Ensure answers come only from uploaded data

Method Overview

1. User submits a question in natural language
2. The question is converted into a vector embedding using Google's embedding model
3. The embedding is compared against stored document embeddings in PostgreSQL using cosine similarity (pg vector)
4. The most relevant document chunks are retrieved (top-k retrieval)
5. Retrieved chunks are passed as context to Google Gemini, which generates a grounded response
6. The answer is streamed back to the user in real time

This prevents hallucination and ensures answers come from real documents.

Data, Algorithms, Tools / Libraries

Data

- PDF compliance documents – NIST CSF, PCI DSS, ISO 27001, and Canadian cybersecurity frameworks
- Text extracted via pdf-parse and chunked into ~800 character segments for precise retrieval
- Stored as 3072-dimensional vector embeddings in PostgreSQL

Algorithms

- Text chunking (sliding window) · Vector embeddings · Cosine similarity search · Top-k retrieval

Tools & Libraries

- Next.js (frontend + API routes) · Drizzle ORM · PostgreSQL + pg vector
- Google Gemini (2.5 Flash-Lite for generation, Gemini embedding model for vectors)

03

Work Completed

Data & Methodology

Data Sources & Selection

- Collected data from several documents
- Filtered and verified over 500 pages of documentation for accuracy and relevance using LLM assistance

Implementation Strategy

- Framework Alignment: Mapped jurisdictional requirements to the NIST CSF Framework to create a structured knowledge base
- Organized data by seven industries and 16 jurisdictions to enable filtering

Challenges Resolved

Handling Massive Frameworks

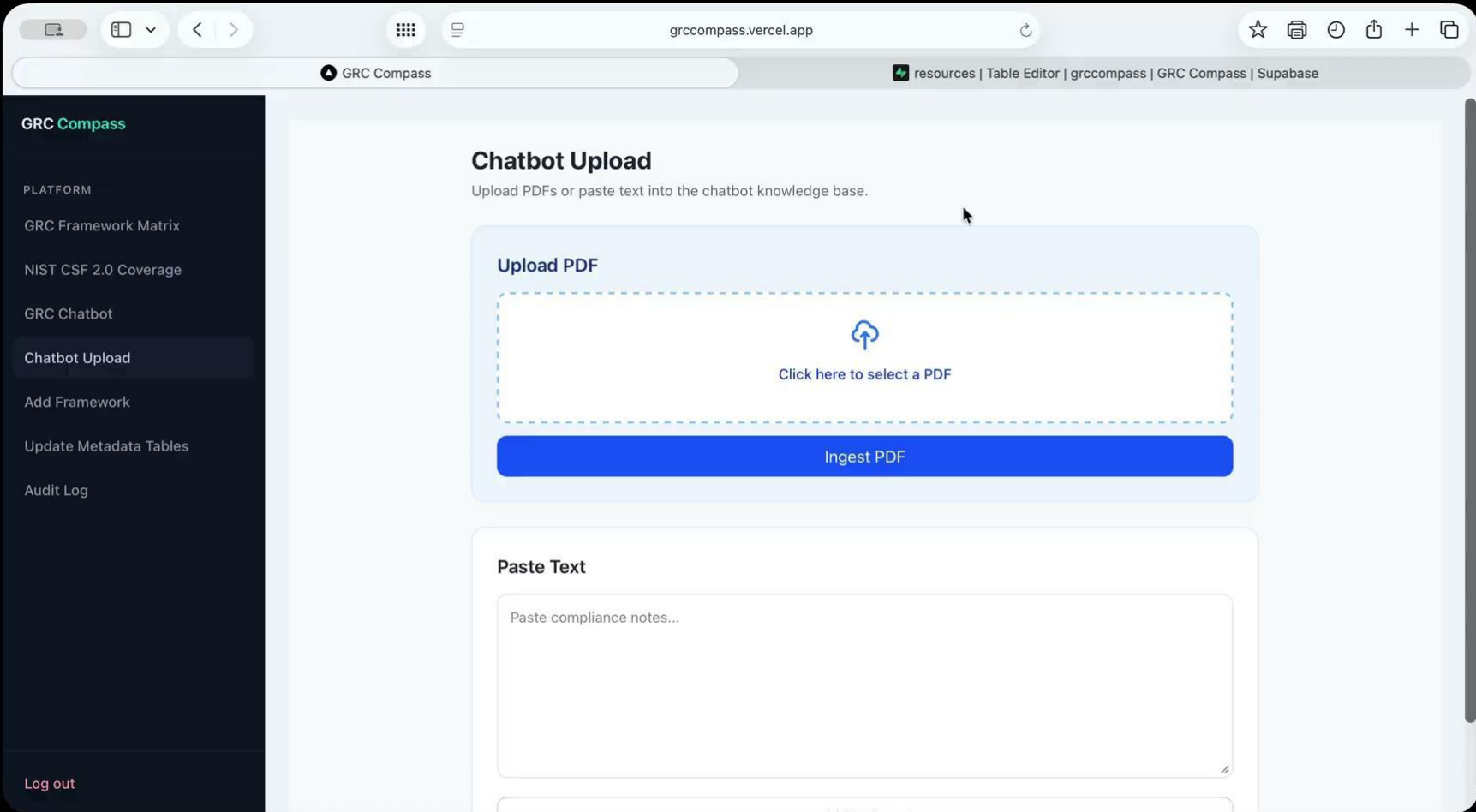
- Problem: AI context windows can't process massive PDF files without losing detail or crashing
- Resolved by implementing chunking and implementing vector embeddings which allows the bot to read and cite specific sections from big documents with high accuracy

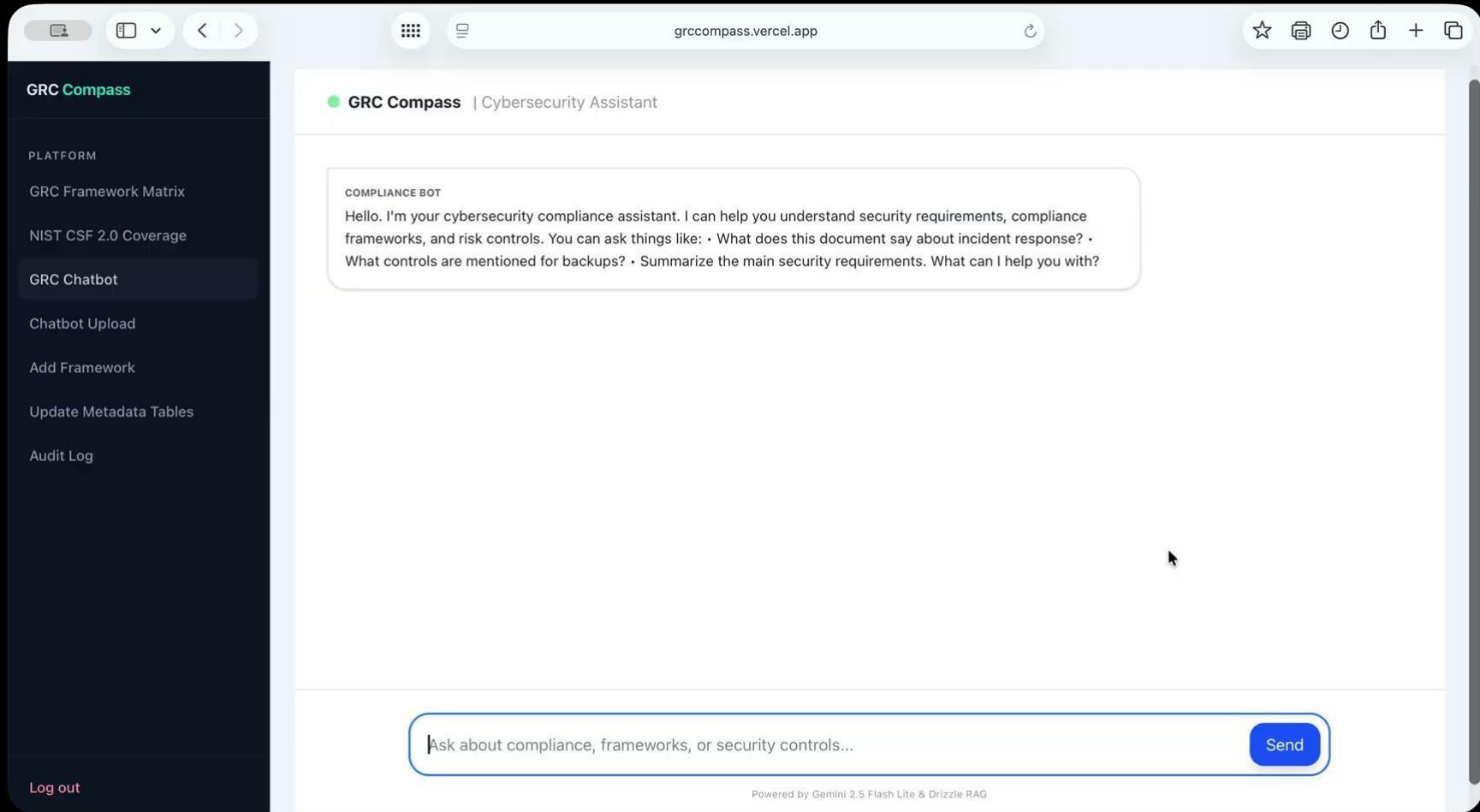
Architectural Flexibility

- Local hosting via ollama to meet strict data requirements
- Security: Allows consulting firms to meet strict data and privacy requirements

04

DEMO





05

Conclusion

Successes

- Transitioned from a static HTML page to a dynamic, interactive web platform.
- Integrated a file-upload feature, allowing users to ingest and analyze custom PDF frameworks in real time.
- Developed a context-aware system that provides natural language responses backed by verifiable PDF citations
- Ensured high speed response utilizing Gemini 2.5 Flash Lite to deliver near instant regulatory insights

Limitations

- Limited to **uploaded documents** (no external real-time data) - RAG
- Response quality depends on **data completeness and accuracy** - Coded keywords to search through
- Requires **paid API usage** (e.g., LLM responses) - Can be costly with multiple users
- Gemini API key uses token-based pricing

	Free Tier	Paid Tier, per 1M tokens in USD
Input price (text, image, video)	Free of charge	\$0.10 (text / image / video) \$0.30 (audio)
Output price (including thinking tokens)	Free of charge	\$0.40

Future Work

Add persistent chat history

- Storing conversations in the database
- Letting users return and continue past chats

Add source citations

- Show exact document and section used

Support for more file types

- Add word file ingestion

Improve document processing

- Add smarter chunking based on paragraphs

06

Thank You
Questions?